Rollen & Verantwoordelijkheden Informatiebeveiliging

ISO 27001:2022 — A.5.2, A.5.4

Documentnummer	ISMS-004
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Dit document definieert de rollen, verantwoordelijkheden en bevoegdheden met betrekking tot informatiebeveiliging binnen [Organisatienaam]. Duidelijke toewijzing voorkomt gaten in de beveiliging en zorgt voor accountability.

2. Organisatiestructuur informatiebeveiliging

```
┌──────────────────────────────────┐
│          Directie / MT           │
│   Eindverantwoordelijk ISMS      │
└──────────────┬───────────────────┘
               │
┌──────────────▼───────────────────┐
│   CISO / IS-verantwoordelijke    │
│   Operationeel verantwoordelijk  │
└──────────────┬───────────────────┘
               │
    ┌──────────┼──────────┐
    ▼          ▼          ▼
┌────────┐  ┌────────┐  ┌────────┐
│IT-beheer│ │Leidingge│ │HR      │
│        │ │venden  │ │        │
└────────┘  └────────┘  └────────┘
               │
```

```
┌──────────▼──────────┐
│  Alle medewerkers   │
└─────────────────────┘
```

3. Rolbeschrijvingen

3.1 Directie / Management Team

Naam/functie	[In te vullen]
Rapporteert aan	N.v.t. (hoogste niveau)

Verantwoordelijkheden:

- Eindverantwoordelijkheid voor informatiebeveiliging en het ISMS
- Goedkeuren van het informatiebeveiligingsbeleid en bijbehorende doelstellingen
- Beschikbaar stellen van voldoende middelen (budget, personeel, tijd)
- Uitvoeren van de managementreview (minimaal jaarlijks)
- Bevorderen van een cultuur van beveiligingsbewustzijn
- Nemen van beslissingen over risicobehandeling boven het mandaat van de CISO

Bevoegdheden:

- Goedkeuren en afwijzen van informatiebeveiligingsbeleid
- Toekennen van budget voor beveiligingsmaatregelen
- Accepteren van restrisico's

3.2 CISO / Informatiebeveiligingsverantwoordelijke

Naam/functie	[In te vullen]
Rapporteert aan	Directie

Verantwoordelijkheden:

- Dagelijkse coördinatie en aansturing van het ISMS
- Opstellen, onderhouden en communiceren van beleid en procedures
- Plannen en coördineren van risicobeoordelingen
- Coördineren van interne audits
- Beheren van het incidentmanagementproces
- Rapporteren aan directie over ISMS-prestaties, incidenten en risico's
- Onderhouden van de Statement of Applicability
- Coördineren van bewustzijnsprogramma's
- Contact onderhouden met toezichthouders en certificeerders

Bevoegdheden:

- Initiëren van correctieve maatregelen
- Escaleren van risico's en incidenten naar directie
- Opvragen van informatie bij alle afdelingen ten behoeve van het ISMS
- Toegang blokkeren bij vermoeden van misbruik (in overleg met IT-beheer)

3.3 IT-beheer / Systeembeheerders

Naam/functie	[In te vullen]
Rapporteert aan	[CISO / IT-manager]

Verantwoordelijkheden:

- Implementeren en beheren van technische beveiligingsmaatregelen
- Beheer van toegangsrechten (provisioning, deprovisioning)
- Uitvoeren van patch- en kwetsbaarheidsbeheer
- Beheer van logging, monitoring en detectiesystemen
- Uitvoeren en testen van backups
- Configuratie en beheer van netwerk- en systeembeveiliging
- Technische ondersteuning bij beveiligingsincidenten

Bevoegdheden:

- Technische configuratiewijzigingen doorvoeren volgens change management procedure
- Noodtoegang tot systemen bij beveiligingsincidenten
- Tijdelijk blokkeren van accounts bij vermoeden van compromittatie

3.4 Leidinggevenden / Afdelingshoofden

Betreft	Alle leidinggevenden
Rapporteert aan	Directie / MT

Verantwoordelijkheden:

- Waarborgen dat medewerkers het beleid kennen en naleven
- Signaleren van beveiligingsrisico's binnen hun afdeling
- Meewerken aan risicobeoordelingen voor hun afdeling
- Zorgen dat nieuwe medewerkers het onboarding-beveiligingsproces doorlopen
- Melden van beveiligingsincidenten bij de CISO
- Toekennen van benodigde toegangsrechten voor hun teamleden (via formeel verzoek)

3.5 HR / Personeelszaken

Naam/functie	[In te vullen]
Rapporteert aan	[Directie / Management]

Verantwoordelijkheden:

- Uitvoeren van screening bij indiensttreding
- Opnemen van geheimhoudingsclausules in arbeidsovereenkomsten
- Coördineren van onboarding-beveiligingstraining
- Melden van in-/uitdiensttreding aan IT-beheer (voor toegangsbeheer)
- Bijhouden van het competentieregister
- Ondersteunen bij disciplinaire maatregelen na beleidsovertreding

3.6 Alle medewerkers

Verantwoordelijkheden:

- Naleven van het informatiebeveiligingsbeleid en alle onderliggende richtlijnen
- Deelnemen aan verplichte bewustzijnstrainingen
- Melden van beveiligingsincidenten, kwetsbaarheden en verdachte situaties
- Beschermen van vertrouwelijke informatie en toegangsgegevens
- Vergrendelen van werkstations bij het verlaten van de werkplek
- Niet delen van wachtwoorden of toegangsgegevens

4. RACI-matrix

Activiteit	Directie	CISO	IT-beheer	Leidinggevenden	HR	Medewerkers
Beleid goedkeuren	**A**	R	C	I	I	I
Risicobeoordeling	A	**R**	C	C	I	I
Technische maatregelen	I	A	**R**	I	I	I
Toegangsbeheer	I	A	**R**	C	C	I
Incidentmelding	I	A	C	C	I	**R**
Incidentrespons	I	**A**	R	C	I	I
Awareness training	A	**R**	I	C	C	I
Interne audit	A	**R**	C	C	I	I
Management review	**R**	A	C	I	I	I
Screening medewerkers	I	C	I	I	**R**	I

R = Responsible (uitvoerend) · A = Accountable (eindverantwoordelijk) · C = Consulted · I = Informed

5. Escalatieprocedure

Niveau	Escalatie naar	Wanneer
1	CISO	Alle beveiligingsincidenten en -risico's
2	Directie / MT	Hoge/kritieke risico's, significante incidenten, budgetaanvragen
3	Externe partijen	Meldplicht AP, NCSC, politie bij strafbare feiten

6. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]